COMITÉ EXÉCUTIF · OCTOBRE 2026

# Risques cyber : où en est Orséa Banque, et ce que nous vous demandons

Synthèse de l’analyse de risques EBIOS RM, de la déclaration d’applicabilité ISO 27001 et du plan de traitement

Présenté par le RSSI · Document de décision

LE MESSAGE CLÉ

# 5 de nos 7 risques cyber majeurs sont aujourd’hui à un niveau élevé. Avec un plan de 805 k€ sur 15 mois, plus aucun ne le reste.

Nous vous demandons d’approuver la politique de sécurité, le budget et les propriétaires de chaque risque.

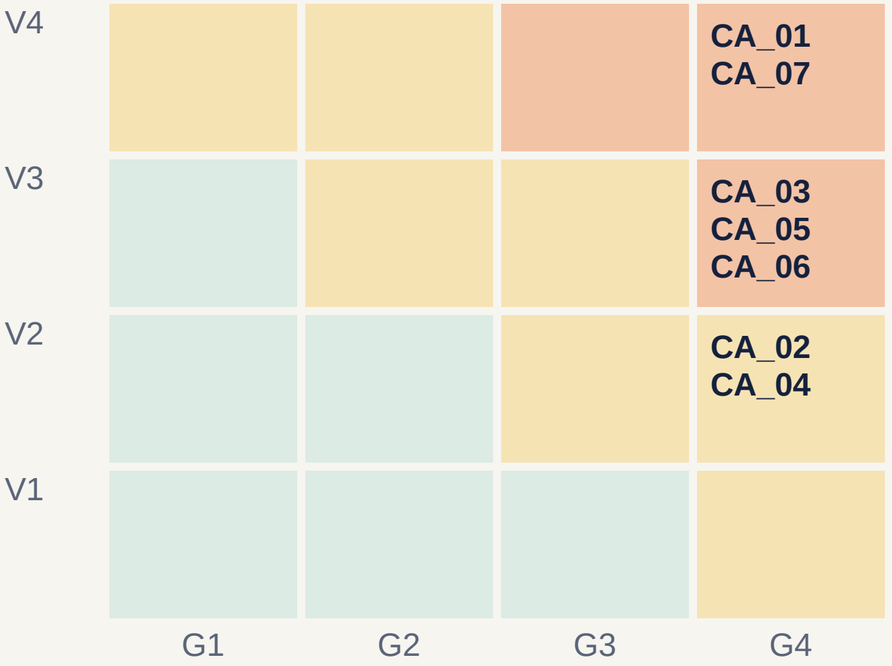
# Sept scénarios menacent nos fonds, nos clients et notre conformité

| Risque | Scénario | Aujourd’hui | Stratégie | Après plan |
|---|---|---|---|---|
| CA_01 | Fraude aux paiements par phishing des clients | **Élevé** | Réduire | Moyen |
| CA_02 | Compromission du processeur de paiement | Moyen | Transférer | Moyen |
| CA_03 | Rançongiciel via phishing des collaborateurs | **Élevé** | Réduire | **Faible** |
| CA_04 | Rançongiciel via l’éditeur du core banking | Moyen | Réduire | **Faible** |
| CA_05 | Agent interne corrompu, abus d’accès | **Élevé** | Réduire | Moyen |
| CA_06 | Comptes ouverts pour blanchir de l’argent | **Élevé** | Réduire | Moyen |
| CA_07 | Clients recrutés comme mules | **Élevé** | Réduire | Moyen |

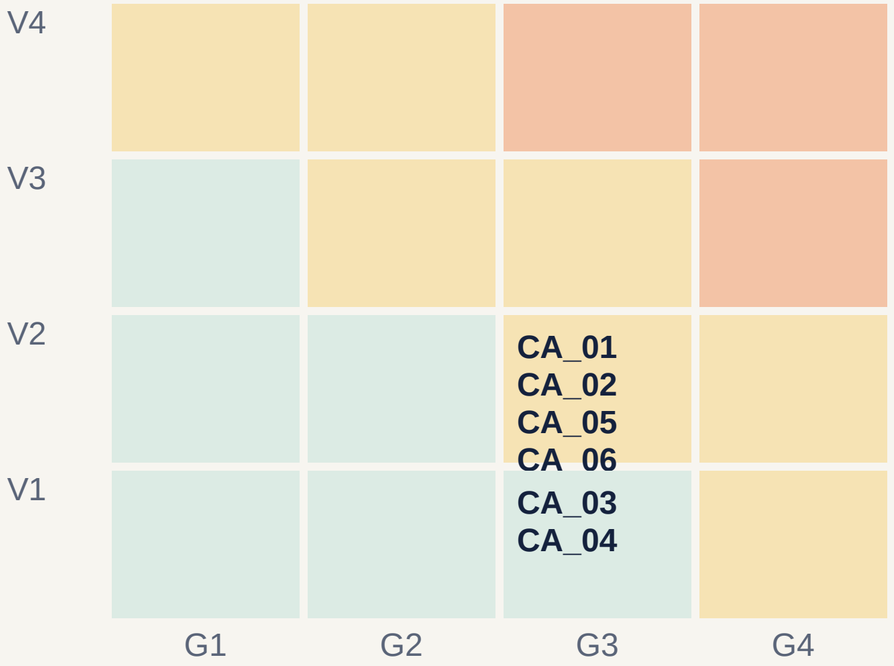
Source : analyse EBIOS RM AR_01. Tous les scénarios ont une gravité maximale (G4) avant traitement.

# Le plan fait sortir tous les risques de la zone rouge

## Aujourd’hui




## Après le plan




V = vraisemblance, G = gravité. Orange foncé : niveau élevé · jaune : moyen · vert : faible.

# Point de départ : 84 des 90 mesures de sécurité ISO 27001 applicables restent à mettre en place

**84**

**non conformes**

Mesure absente ou seulement prévue

**6**

**partiellement conformes**

Dont l’authentification forte des clients, seule mesure déjà active

**3**

**exclues**

Sécurité physique des serveurs, assurée par AWS

Cet écart est attendu au lancement d’un système de management de la sécurité : il fixe le point de départ que le plan doit combler.

Source : déclaration d’applicabilité ISO/IEC 27001:2022 (audit AUD_01), 93 mesures de l’Annexe A.

# Un plan de 805 k€, dont 71 % engagés d’ici mars 2027

PRIORITÉ 1 · D’ICI MARS 2027

## 575 k€

**12 mesures**

Surveillance anti-blanchiment, EDR et SOC, sauvegardes immuables, MFA administrateurs, plan de crise DORA

PRIORITÉ 2 · D’ICI JUIN 2027

## 220 k€

**8 mesures**

KYC renforcé, cyber-assurance, sensibilisation au phishing, tests des mises à jour

PRIORITÉ 3 · D’ICI DÉC. 2027

## 10 k€

**1 mesure**

Campagnes contre le recrutement de mules auprès des clients

Les mesures sont portées par 8 responsables : RSSI, DSI, conformité, produit, achats, finance, relation client et communication.

Coûts : ordres de grandeur de la première année, à confirmer par devis. Source : plan de traitement Orséa Banque.

# Depuis janvier 2025, DORA rend la direction responsable du risque numérique

Article 5

## La direction répond du risque

Le COMEX approuve le cadre de gestion du risque, alloue le budget et en porte la responsabilité finale.

Articles 17 à 19

## Les incidents se déclarent

Tout incident majeur est notifié à l’ACPR dans des délais courts : il faut un processus prêt avant l’incident.

Articles 28 à 30

## Les prestataires s’encadrent

Nos contrats avec l’éditeur du core banking, le processeur de paiement et AWS doivent contenir des clauses minimales.

Ne rien faire n’est donc pas une option : l’ACPR peut contrôler et sanctionner l’absence de ce cadre.

Source : règlement (UE) 2022/2554 (DORA), applicable depuis le 17 janvier 2025.

# Nous vous demandons quatre décisions aujourd’hui

| | |
|---|---|
| 1 | Approuver la politique de sécurité (PSSI v0.1) et sa diffusion à tous les collaborateurs et prestataires |
| 2 | Valider le budget de 805 k€, dont 575 k€ engagés immédiatement pour la priorité 1 |
| 3 | Désigner les propriétaires des 7 risques, qui acceptent les risques résiduels |
| 4 | Inscrire un point trimestriel sur les risques cyber à l’ordre du jour du COMEX |